# GOVERNANCE, RISK & COMPLIANCE

# CAPSTONE REPORT

**PREPARED BY:**

**IYABO UWADIAE, PEACE AKINWALE & BENEDICT NWAFOR**

**CLIENT: BENTO FINTECH LTD**

**DATE: JUNE 2026**

**COURSE/COHORT: CYBERSECURITY/C25-12**

**ASSESSMENT TYPE: INFORMATION SECURITY POLICY DEVELOPMENT & AWARENESS IMPLEMENTATION**

# Team Formation & Role Assignment

To ensure effective development, implementation, and governance of Bento FinTech Ltd information security framework, a cross-functional Information Security Governance Team was established. Each team member was assigned specific responsibilities based on their expertise and role within the policy lifecycle.

**Chief Information Security Officer (CISO)**
The Chief Information Security Officer (CISO) provides executive leadership and strategic oversight for information security governance across Bento. This role serves as the highest security decision-making authority within the organization and is responsible for establishing security objectives aligned with business goals. The CISO provides governance oversight, reviews organizational risks, and grants final approval for all security policies before implementation.

**Information Security Manager**
The Information Security Manager oversees operational security activities and coordinates the implementation of approved security policies and controls. This role manages security implementation plans, monitors compliance activities, and ensures security initiatives are effectively integrated into organizational operations. The Information Security Manager also serves as the policy owner and reviewer, ensuring policies remain current and effective.

**IAM Specialist / Security Engineer**
The IAM Specialist/Security Engineer is responsible for implementing technical security controls related to identity and access management across the organization. This role develops and manages user access matrices, authentication mechanisms, and account management processes. Additionally, the IAM Specialist performs technical reviews to ensure that policy requirements are effectively translated into security technologies and operational controls.

**Compliance Officer / Policy Analyst**
The Compliance Officer/Policy Analyst ensures that organizational policies and procedures comply with ISO/IEC 27001 and ISO/IEC 27002:2022 requirements. This role is responsible for compliance management and standards mapping activities, including developing ISO control mapping documentation, preparing audit evidence, and conducting compliance assessments. The Compliance Officer also acts as the primary policy author and compliance reviewer throughout the policy lifecycle.

**Awareness and Training Coordinator**
The Awareness and Training Coordinator is responsible for developing and promoting a strong security culture through employee education and awareness activities. This role coordinates Wizer awareness campaigns, develops training materials, tracks employee completion reports, and manages security communications. The Awareness and Training Coordinator also serves as the communication and training owner for all security awareness initiatives.

# BENTO FINTECH LTD

# INFORMATION SECURITY POLICY

| Document Title | Information Security Policy |
|---|---|
| Document Number | BENTO-POL-ISP-001 |
| Version | 1.0 |
| Classification | Internal - Confidential |
| Status | **APPROVED** |
| Author | Compliance Officer / Policy Analyst |
| Reviewer | Chief Information Security Officer (CISO) |
| Approved By | CEO |
| Issue Date | 08 June 2026 |
| Next Review Date | 08 June 2027 |
| Document Location | Bento ISP Repository |
| Distribution List | Executive Team, IT, & All Departments |
| Reference Document | • ISO/IEC 27001:2022 |

**Confidentiality Notice: This document is the property of Bento FinTech Ltd. and is classified as Internal. Unauthorized disclosure is prohibited.**

## 1. Purpose

Bento FinTech Ltd. is committed to protecting the confidentiality, integrity, and availability of all information assets entrusted to it by customers, employees, partners, and regulators. This Information Security Policy (ISP) establishes the overarching governance framework within which all information security activities at Bento shall be conducted.

This policy is aligned with ISO/IEC 27001:2022 (Clause 5.2 – Policy) and ISO/IEC 27002:2022 (Control 5.1 – Policies for Information Security). It forms the apex policy document from which all subsidiary information security policies, standards, and procedures derive their authority.

## 2. Scope & Applicability

This policy applies, without exception, to all Bento employees, including permanent, fixed-term, part-time, and remote workers. Contractors, consultants, agency staff, and temporary workers with access to Bento information systems. Third-party service providers, vendors, and business partners who process or have access to Bento data or systems. All information assets regardless of format (digital, physical, verbal) and regardless of location (on-premises, cloud, remote). All Bento operational sites and any location from which Bento business is conducted.

This policy applies globally across Bento's European operations and is enforceable from the date of approval.

## 3. Roles & Responsibilities

| Roles | Responsibilities |
|---|---|
| **Chief Information Security Officer (CISO)** | Provides executive ownership of this policy; ensures adequate resources are allocated; approves policy updates; acts as ultimate escalation point for security governance matters; reports security posture to the Board. |
| **Information Security Manager** | Coordinates day-to-day implementation of this policy; manages the information security programme; commissions audits; reviews and updates subsidiary policies; monitors the risk register. |
| **Compliance Officer / Policy Analyst** | Maps policy requirements to ISO/IEC 27002:2022 controls; monitors regulatory compliance; prepares audit evidence; tracks and reports policy violations. |
| **IAM Specialist / Security** | Implements technical controls mandated by this and subsidiary policies; manages identity and access controls; conducts security engineering reviews. |
| **Awareness & Training Coordinator** | Develops and delivers the security awareness programme; administers the Wizer platform; tracks employee completion of mandatory security training. |
| **All Line Managers and Department Heads** | Ensure direct reports understand and comply with this policy; report security incidents and non-compliance promptly; incorporate security responsibilities into performance objectives. |
| **All Employees and Third Parties** | Read, understand, and comply with this policy and all subsidiary security policies; complete mandatory security awareness training; report actual or suspected security incidents immediately. |

## 4. Policy Statement

### 4.1 Information Security Governance

**Bento shall:**

- Establish, implement, maintain, and continually improve an Information Security Management System (ISMS) aligned with ISO/IEC 27001:2022. The ISMS shall be supported by a documented suite of policies, standards, and procedures approved by executive leadership.
- Information security is a business-critical function. Executive ownership rests with the CISO, who shall report the security posture to the Board at least quarterly. The CISO shall have the authority and resource to fulfil this mandate.
- A formal information risk management process shall be maintained. All identified information risks shall be recorded in the Risk Register, assessed using a documented methodology, and treated in accordance with Bento's risk appetite, which is defined and approved by the Board annually.

### 4.2 Information Security Principles

All information security activities at Bento shall be governed by the following non-negotiable principles:

| Principles | Requirements |
|---|---|
| **Confidentiality** | Information must be accessible only to those with a legitimate, authorised business need. Access must be controlled through formal processes. |
| **Integrity** | The accuracy and completeness of information must be protected. Unauthorised modification, deletion, or corruption of data is prohibited. |
| **Availability** | Information and supporting systems must be available to authorised users when required. Business continuity and disaster recovery plans shall be maintained. |
| **Accountability** | All actions on Bento information systems must be attributable to a specific individual. Audit logging shall be enabled on all critical systems. |
| **Compliance** | All employees and systems must comply with applicable laws, regulations, and contractual obligations. Non-compliance is treated as a disciplinary matter. |
| **Continuous Improvement** | Security controls shall be regularly reviewed and improved based on threat intelligence, audit findings, and lessons learned from security incidents. |

### 4.3 Information Security Policy Compliance

- Compliance with this policy and all subsidiary security policies is mandatory for all persons within scope.
- Compliance shall be monitored through a combination of technical controls, audits, access reviews, and behavioural monitoring.
- All employees must acknowledge receipt and understanding of this policy upon joining Bento and annually thereafter. Records of acknowledgement shall be retained by the Awareness & Training Coordinator for a minimum of three years.
- Mandatory information security awareness training must be completed by all employees within 30 days of commencement of employment and annually thereafter. Completion rates shall be monitored and reported to the CISO monthly.

### 4.4 Information Asset Protection Requirements

Employees and authorized users shall:

- Protect organizational information assets from unauthorized access, disclosure, modification, or destruction.

- Handle customer financial information according to established security requirements.
- Use approved encryption methods for sensitive information transmission and storage.
- Report suspected security incidents immediately.
- Follow approved information handling procedures.

### 4.5 Access Control Requirements

Users shall:

- Access only information and systems necessary to perform assigned duties.
- Use unique user accounts and maintain secure passwords.
- Enable Multi-Factor Authentication (MFA) where required.
- Never share passwords or authentication credentials.
- Immediately report unauthorized access attempts.

### 4.6 security Awareness Requirements

Bento shall:

- Conduct periodic information security awareness training.
- Ensure all personnel complete mandatory security training.
- Deliver phishing awareness exercises and educational campaigns.
- Communicate policy updates to employees.
- Maintain training completion records.

### 4.7 Incident Reporting Requirements

Employees and contractors shall:

- Report suspected or actual information security incidents immediately.
- Cooperate with incident investigations.
- Preserve evidence related to security incidents.
- Follow incident response procedures established by the Information Security Team.

## 5. Exceptions

Any exceptions to this policy must be approved by Information Security Management and documented through a formal risk assessment process. Approved exceptions shall include compensating controls and specified review periods.

## 6. Policy Violations

Failure to comply with this policy may result in disciplinary action, including but not limited to:

- Verbal or written warnings
- Mandatory retraining
- Suspension of system access privileges
- Termination of employment or contracts
- Legal action where applicable

## 7. References

ISO/IEC 27002:2022

| | |
|---|---|
| Control 5.1 | Policies for Information Security |
| Control 5.2 | Information Security Roles and Responsibilities |
| Control 5.9 | Inventory of Information and Other Associated Assets |
| Control 5.15 | Access Control |
| Control 5.24 | Information Security Incident Management Planning and Preparation |
| Control 6.3 | Information Security Awareness, Education, and Training |

## 8. Approval Evidence

Simulated Approval Email

**From: Iyabo Uwadiae<ciso@bento.com>**
To: Information Security Governance Team <isgt@bento.com>
Date: 07 June 2026, 09:42 AM
**Subject: APPROVED – Information Security Policy (BENTO-POL-ISP-001 v1.0)**

Dear Team,

I have reviewed the Information Security Policy (BENTO-POL-ISP-001, Version 1.0) and am pleased to formally APPROVE this document for immediate implementation across all Bento operations.

This policy is effective as of 01 June 2026. All department heads are required to ensure their teams acknowledge and comply with this policy within 30 days of issue.

Regards,
**Iyabo Uwadiae | Chief Information Security Officer | Bento FinTech Ltd.**

# BENTO FINTECH LTD

# DATA PROTECTION AND PRIVACY POLICY

| Document Title | Data Protection and Privacy Policy |
|---|---|
| Document Number | BENTO-DPP-001 |
| Version | 1.0 |
| Classification | Internal - Confidential |
| Status | **APPROVED** |
| Author | Information Security Governance Team |
| Policy Owner | Compliance Officer |
| Reviewer | Information Security Manager |
| Approved By | Chief Information Security Officer (CISO) |
| Issue Date | 09 June 2026 |
| Next Review Date | 09 June 2027 |
| Document Location | Bento ISP Repository |
| Distribution List | Executive Team, IT, & All Departments |
| Reference Document | • ISO/IEC 27001:2022 |

## 1. Purpose

The purpose of this Data Protection and Privacy Policy is to establish requirements for the collection, processing, storage, transmission, and disposal of personal and sensitive information within Bento FinTech Ltd. This policy supports ISO/IEC 27001:2022, ISO/IEC 27002:2022, UK GDPR, and applicable data protection regulations.

## 2. Scope and Applicability

This policy applies to all employees, contractors, vendors, consultants, customer financial information, employee records, cloud systems, digital records, and physical records.

## 3. Policy Objectives

1. Protect customer and employee information.
2. Ensure lawful processing of personal information.
3. Reduce data breach risks.
4. Support regulatory compliance.
5. Maintain customer trust.

## 4. Roles and Responsibilities

Employees must protect data and report incidents. The Information Security Team monitors compliance and investigates incidents. The Compliance Officer ensures regulatory compliance. Management supports implementation and enforcement.

## 5. Policy Statements

- Policy Statement 1: Data Classification – Data must be classified as Public, Internal, Confidential, or Restricted.

- Policy Statement 2: Access Control – Access must follow least privilege, MFA must be enabled, and shared accounts are prohibited.
- Policy Statement 3: Data Protection and Privacy – Personal data must be collected lawfully, protected appropriately, retained only as necessary, and securely disposed of.

**6. Compliance Monitoring**
Compliance will be monitored through audits, access reviews, security assessments, and incident investigations.

**7. Non-Compliance**
Violations may result in disciplinary action, additional training, suspension of access, or termination.

**8. Policy Review**
This policy shall be reviewed annually or following significant business, regulatory, or security changes.

**ISO/IEC 27001:2022 Alignment**
A.5.12 Classification of Information
A.5.15 Access Control
A.5.16 Identity Management
A.5.18 Access Rights
A.5.34 Privacy and Protection of PII
A.6.3 Information Security Awareness, Education and Training

**Approval**
Approved By: Peace Akinwale
Chief Information Security Officer (CISO)
Bento FinTech Ltd
Date: 09 June 2026

# BENTO FINTECH LTD

# CLEAR DESK AND CLEAR SCREEN POLICY

| Document Title | Clear Desk and Clear Screen Policy |
|---|---|
| **Document Number** | BENTO-POL-CDCSP-001 |
| **Version** | 1.0 |
| **Classification** | Internal - Confidential |
| **Status** | **APPROVED** |
| **Author** | Compliance Officer / Policy Analyst |
| **Reviewer** | Chief Information Security Officer (CISO) |
| **Approved By** | CEO |
| **Issue Date** | 08 June 2026 |
| **Next Review Date** | 08 June 2027 |
| **Document Location** | Bento CDCSP Repository |
| **Distribution List** | All Departments |
| **Reference Document** | ISO/IEC 27002:2022 |

## 1. ISO/IEC 27002:2022 Alignment

**Domain:** Physical Controls

**Sub-Domain:** Physical Security

**Control Number:** 7.7

**Control Name:** Clear Desk and Clear Screen

## 2. Purpose

The purpose of this policy is to ensure that sensitive organizational information is protected from unauthorized access, disclosure, loss, theft, or damage by maintaining clear desks and secure screens when workstations are unattended. This policy supports the organization's information security objectives and compliance with ISO/IEC 27002:2022 Control 7.7.

## 3. Scope

This policy applies to all employees, contractors, consultants, interns, temporary workers, and third-party users who access, process, store, or manage organizational information and information systems.

## 4. Policy Statement

The organization requires all personnel to maintain a clear desk and clear screen environment to reduce the risk of unauthorized access to sensitive information.

### 4.1 Clear Desk Requirements

**Employees shall:**

- Store confidential and sensitive documents in locked cabinets or drawers when not in use.
- Remove all sensitive documents from desks before leaving the workplace.
- Secure removable media such as USB drives and external storage devices.
- Collect printed materials immediately from printers and photocopiers.
- Dispose of confidential documents using approved shredding procedures.

### 4.2 Clear Screen Requirements

**Employees shall:**

- Lock computer screens when leaving workstations unattended.
- Enable automatic screen locking after ten minutes of inactivity.
- Ensure sensitive information displayed on screens cannot be viewed by unauthorized individuals.
- Log off systems at the end of the workday when appropriate.
- Protect laptops and mobile devices from unauthorized viewing in public locations.

## 5. Roles and Responsibilities

**Employees**

- Comply with all requirements of this policy.
- Report observed violations to management or the Information Security Team.

**Department Managers**

- Ensure employees understand and comply with this policy.
- Address non-compliance within their departments.

**Information Security Team**

- Monitor compliance with the policy.
- Conduct audits and inspections.
- Report policy violations to management.

**Human Resources**

- Support disciplinary actions resulting from policy violations.
- Ensure policy awareness training is provided.

**Senior Management**

- Provide oversight and resources necessary for policy implementation.

## 6. Policy Compliance Framework

### 6.1 Monitoring and Reporting Mechanisms

**The organization shall monitor compliance through:**

- Monthly workplace inspections.
- Quarterly internal security audits.
- Automated monitoring of screen-lock configurations.
- Random spot checks of offices, meeting rooms, and shared workspaces.

Audit results shall be documented and reported to department managers and senior management.

### 6.2 Assigned Responsibilities

| Role | Responsibility |
|---|---|
| **Employees** | Follow policy requirements |
| **Managers** | Monitor department compliance |
| **Information Security Team** | Conduct audits and monitoring |
| **Human Resources** | Manage disciplinary processes |
| **Senior Management** | Review compliance reports |

### 6.3 Review Timelines

| Activity | Frequency |
|---|---|
| **Workplace Inspection** | Monthly |
| **Security Audit** | Quarterly |
| **Compliance Review** | Quarterly |

| | |
|---|---|
| **Policy Review** | Annually |
| **Policy Update** | Every 12 Months |

### 6.4 Escalation Procedures for Non-Compliance

**First Violation**

- Verbal warning from supervisor.
- Awareness coaching provided.

**Second Violation**

- Written warning.
- Mandatory security awareness training.

**Third Violation**

- Escalation to Human Resources and Information Security Management.
- Corrective action plan required.

**Serious Violation**

- Formal investigation.
- Suspension of system access if necessary.
- Additional disciplinary action in accordance with company policies.

## 7. Exceptions

Any exception to this policy must be documented, risk-assessed, and approved by the Chief Information Security Officer (CISO).

## 8. Enforcement

Failure to comply with this policy may result in disciplinary action, including revocation of system access, suspension, termination of employment, or legal action where applicable.

## 9. References

- ISO/IEC 27002:2022 Control 7.7 – Clear Desk and Clear Screen
- ISO/IEC 27001:2022 Information Security Management Systems
- Organizational Information Security Policy Framework

# BENTO FINTECH LTD

# POLICY COMPLIANCE FRAMEWORK

| Document Title | Information Security Policy |
|---|---|
| Document Number | BENTO-FWK-PCF-001 |
| Version | 1.0 |
| Classification | Internal - Confidential |
| Status | **APPROVED** |
| Issue Date | 08 June 2026 |
| Next Review Date | 08 June 2027 |
| Document Location | Bento Frame-Work Repository |
| Reference Document | • Information Security Governance \| ISO/IEC 27001:2022 & 27002:2022 Aligned |

## 1. Purpose

The purpose of this Policy Compliance Framework is to establish a structured approach for monitoring, enforcing, reviewing, and improving compliance with Bento's information security policies. The framework ensures that all employees, contractors, third-party vendors, and stakeholders adhere to established security requirements while supporting compliance with ISO/IEC 27001:2022 and ISO/IEC 27002:2022 standards.

## 2. Objectives

The framework aims to:

- Monitor adherence to information security policies.
- Identify and address non-compliance issues.
- Assign accountability for compliance activities.
- Establish reporting and review processes.
- Promote continuous improvement of security controls.
- Support audit readiness and regulatory compliance.

## 3. Scope

This framework applies to:

All Bento employees, contractors, consultants, third-party vendors, business partners, information systems and technology resources, cloud platforms and payment systems and security awareness activities.

## 4. Monitoring and Reporting Mechanisms

Bento will establish continuous monitoring mechanisms to ensure compliance with security policies and identify potential control weaknesses.

| Monitoring Activity | Monitoring Method | Reporting Frequency | Responsible Role |
|---|---|---|---|
| User access monitoring | Review of user accounts and access logs | Monthly | IAM Specialist / Security Engineer |
| Security incident monitoring | Incident reports and SIEM alerts | Continuous | Information Security Manager |
| Security awareness monitoring | Wizer completion reports and employee assessments | Monthly | Awareness and Training Coordinator |
| Internal policy audits | Compliance checklists and audit reviews | Quarterly | Compliance Officer / Policy Analyst |
| Vulnerability assessments | Security scans and risk assessments | Quarterly | Security Engineer |
| Policy adherence reviews | Departmental compliance reviews | Quarterly | Information Security Manager |
| Third-party compliance monitoring | Vendor assessments and contracts review | Semi-annually | Compliance Officer |

### 4.1 Reporting Procedures

The following reporting procedures will be implemented:

#### 4.1.1 Operational Reports

Generated by security personnel and submitted monthly:

- Security incident reports
- Access review reports
- Vulnerability reports
- Wizer completion reports

#### 4.1.2 Management Reports

Prepared for executive leadership quarterly:

- Compliance status
- Key risk indicators
- Audit findings
- Policy violation trends

### 4.1.3 Executive Reports

Prepared by the CISO:

- Overall security posture assessment
- Major risks and remediation plans
- Regulatory compliance status
- Strategic security recommendations

## 5. Assigned Responsibilities

The responsibility for policy compliance shall be shared across different governance roles.

| Role | Responsibilities |
|---|---|
| **Chief Information Security Officer (CISO)** | Provide strategic oversight, approve policies, review escalated compliance issues, and authorize corrective actions |
| **Information Security Manager** | Coordinate policy implementation, monitor operational compliance, and manage remediation activities |
| **IAM Specialist / Security Engineer** | Monitor technical controls, access rights, and security configurations |
| **Compliance Officer / Policy Analyst** | Conduct compliance assessments, maintain audit evidence, and perform ISO control mapping |
| **Awareness and Training Coordinator** | Manage Wizer activities, awareness programs, and completion tracking |
| **Department Managers** | Ensure departmental compliance and communicate security requirements |
| **Employees** | Follow policy requirements and report security concerns |

## 6. Review Timelines

Security policies and compliance activities shall undergo periodic review to ensure effectiveness and alignment with organizational objectives.

| Activity | Review Timeline | Responsible Role |
|---|---|---|
| User access review | Quarterly | IAM Specialist |
| Security awareness completion review | Monthly | Awareness Coordinator |
| Internal audit review | Quarterly | Compliance Officer |
| Vulnerability assessment review | Quarterly | Security Engineer |
| Security policy review | Annually | Information Security Manager |
| Risk assessment review | Semi-annually | CISO |
| Vendor security review | Semi-annually | Compliance Officer |
| Continuous monitoring review | Continuous | Security Team |

### 7. Escalation Procedures for Non-Compliance

When non-compliance with security policies is identified, the issue shall be escalated according to severity and impact.

| Levels | Incidents | Actions | Responsible |
|---|---|---|---|
| **Minor Non-Compliance** | • Failure to complete awareness training<br>• Minor policy documentation errors<br>• Delayed completion of assigned tasks | • Inform employee and direct manager<br>• Provide awareness guidance<br>• Correct issue within five business days | Information Security Manager |
| **Moderate Non-Compliance** | • Unauthorized software installation<br>• Failure to follow access procedures<br>• Repeated policy violations | • Document incident<br>• Notify department manager<br>• Implement corrective action plan<br>• Conduct additional training | Information Security Manager and Compliance Officer |
| **Major Non-Compliance** | • Unauthorized access to sensitive information<br>• Data handling violations<br>• Failure to comply with regulatory requirements | • Immediate investigation<br>• Restrict system access<br>• Notify CISO<br>• Initiate disciplinary procedures | CISO and Security Team |
| **Critical Non-Compliance** | • Intentional data theft<br>• Fraudulent activities<br>• Insider threats<br>• Severe regulatory breaches | • Immediate account suspension<br>• Executive notification<br>• Legal and HR involvement<br>• Incident response activation | CISO, Executive Leadership, HR, and Legal Team |

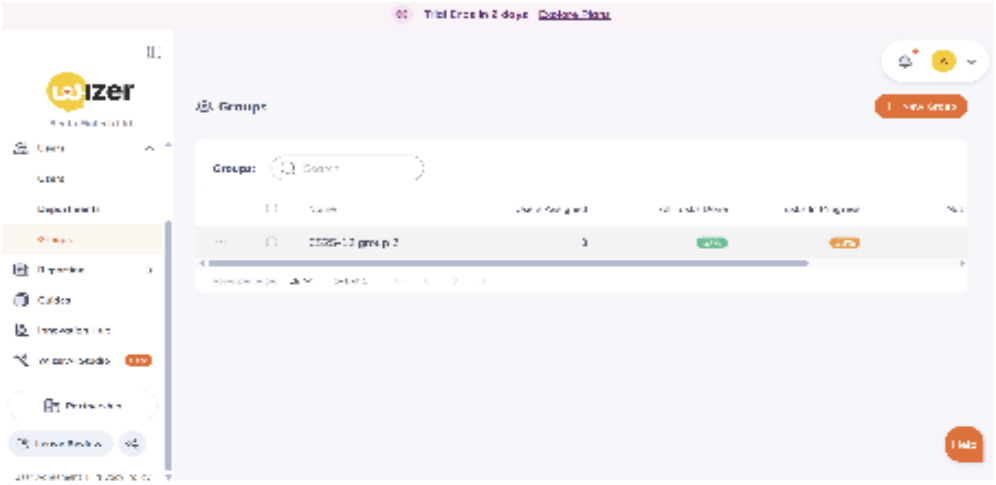
### 8. Continuous Improvement Process

To ensure long-term sustainability of the framework, Bento will:

- Conduct annual policy reviews.
- Perform lessons-learned exercises after incidents.
- Implement corrective and preventive actions.
- Monitor Key Performance Indicators (KPIs).
- Update awareness content and training programs.
- Improve controls based on audit findings and emerging threats.

# Governance and Policies Project Report

## Group Creation



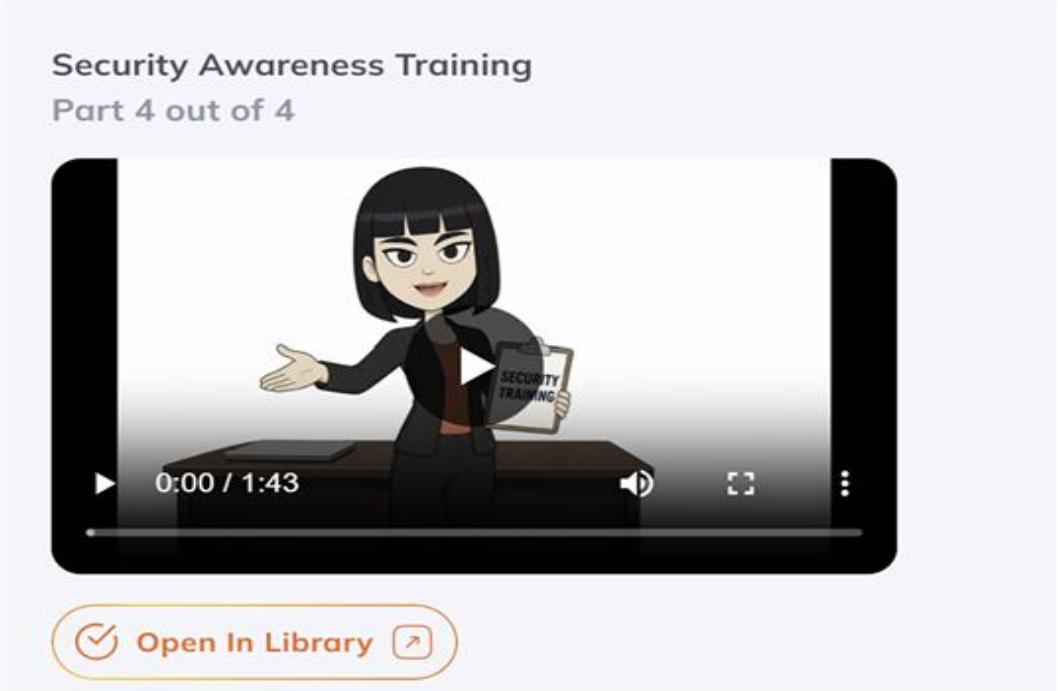
CS25-12 Group 2 was created to manage cybersecurity awareness training and policy assignments for users.

## Policy Upload and Acknowledgement



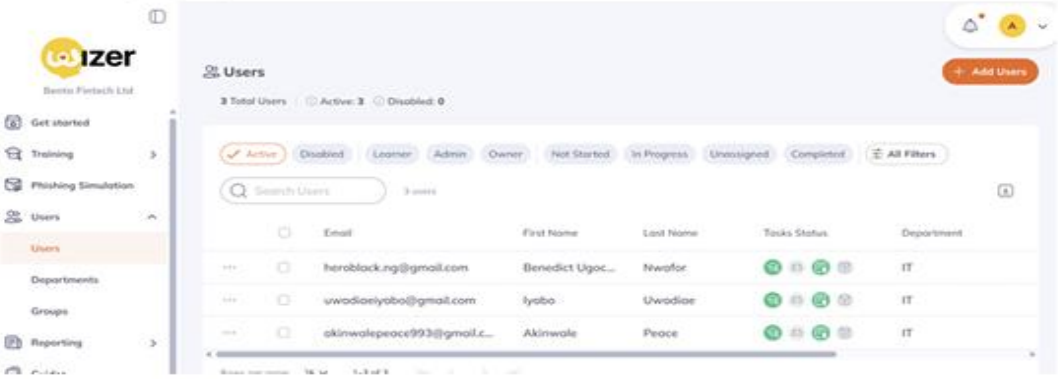
The Data Protection and Privacy Policy, Information Security Policy, and Clear Desk and Clear Screen Policy were uploaded and acknowledged by all users.

## Security Awareness Training Video




A custom Security Awareness Training video was created and delivered through the Wizer platform to improve user awareness of cybersecurity risks and responsibilities.

## Training Completion




All users successfully completed their assigned tasks, including acknowledging the uploaded policies and completing the security awareness training video.